

RISK ASSESSMENT – ABC RETAIL STORE

Written by Kelly Lindsay

BUSINESS OVERVIEW AND RISK ASSESSMENT SCOPE

ABC Retail Store is an emerging business that sells clothes and accessories through both in-store and online platforms. As the business expands, its primary goal is to maintain a trusted reputation in line with its customer base. To achieve this goal, the business has placed a new emphasis on prioritising the protection of its digital infrastructure. The purpose of this risk assessment is to identify and analyse cybersecurity threats that could impact operations, legal compliance and reputation. By proactively addressing these threats, the store aims to strengthen its security posture, mitigate vulnerabilities, and ensure resilience against future cyber risks.

STAKEHOLDER IDENTIFICATION

Please find a list below of all stakeholders observed in ABC Retail Store. These stakeholders are individuals and organisations that play a role in the store's operations and have the potential to both directly and indirectly impact the company's cybersecurity posture.

INTERNAL STAFF (MANAGEMENT & EMPLOYEES)

- **Store Manager** – oversees daily operations and strategic decisions. Generates rosters and requires access to server customers and potentially deliver customer refunds, exchanges etc.
- **Area Manager** – oversees multiple physical stores and ensures continuity between stores. Requires access to deliver reports on success of stores etc.
- **Sales Associates** – handles in-store customer interactions and sales. Requires staff access to do this.
- **E-commerce Manager** – manages the online store and oversees processing of online sales.
- **Warehouse Staff** – Uses systems to track stock and fulfill online orders. Has access to customer details including postal addresses.
- **Online Customer Support Representatives** – interact with customers, access personal and order information to ensure timely delivery of online orders and deliver expert customer service.
- **Accounts / Finance Representatives** – access sensitive financial information and records, including payment of staff and accounting records of customer invoices etc.
- **IT Staff Technicians** – maintain systems, networks and software, as well as perform troubleshooting across the business. May require root access to systems.
- **Marketing team** – manages customer data, digital campaigns and social media accounts.
- **Executives / Business Owners** – make high-level decisions and often have wide access to systems.
- **HR Staff** – handles and oversees employee data and records.

- **Product Designers** – create new clothing and accessories and may use proprietary digital tools and design files.
- **Purchasing / Procurement Staff** – orders clothing products and accessories to fulfill orders. Oversees delivery of products into warehouse.
- **Production Staff / Manufacturers** – involved in making products. May use connected machinery or software-based design files.
- **Quality Assurance** – oversees quality of product and system processes.

EXTERNAL PARTNERS & THIRD PARTIES

- **Web Hosting Provider** – hosts the online store and is responsible for server upkeep and security.
- **Software Vendors** – provide the e-commerce platform and business applications, such as Shopify, WordPress.
- **Payment Processors** – handles online and in-store credit/debit card transactions.
- **Delivery and Logistics Companies** – handles shipping of products to customers and interacts with order data.
- **IT Consultants / Managed Service Providers (MSPs)** – May provide outsourced IT or security services.
- **Marketing Agencies / Contractors** – may have access to customer data for campaigns. Could be a photographer who has access to new product details.
- **Legal and Compliance Advisors** – help the store meet regulatory and legal requirements.
- **Cloud Service Providers** – store data or host applications used by the business.
- **Mobile Device Vendors / Telecom Providers** – provide mobile hardware or network access for employees.
- **Auditors / Assessors** – conduct compliance or financial audits and may access sensitive data.
- **Repair Persons** – provide on-site repairs and have the potential to access systems.

CUSTOMERS

- **In-store Customers** – make physical purchases and may share payment details and/or loyalty information.
- **Online Shoppers** – create accounts, store personal data including first name, last name, email, phone number, billing details and credit card information, home and postal address.
- **Newsletter Subscribers / Loyalty Program Members** – provide personal details and receive marketing communications.

CRITICAL INFORMATION ASSETS

Below is a comprehensive list of critical information assets for ABC Retail Store, covering both physical and digital assets essential to operations and could cause significant disruption if compromised.

DIGITAL ASSETS

- **Customer Database** – contains personal and payment information of online and in-store customers. A breach could lead to identity theft, legal action, and loss of trust.

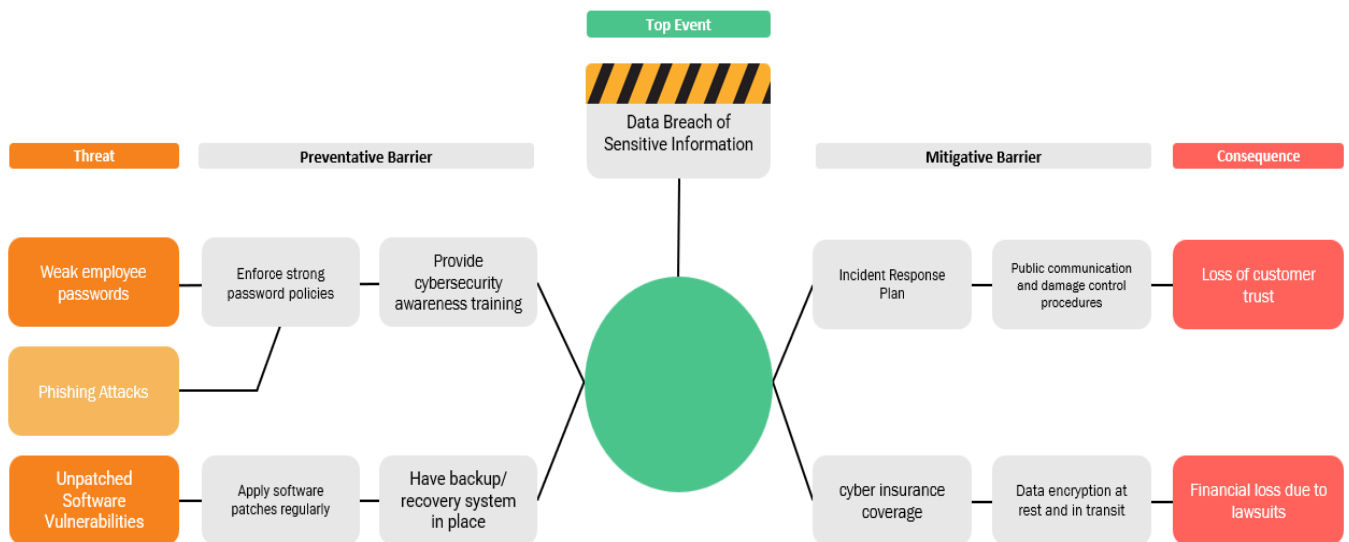
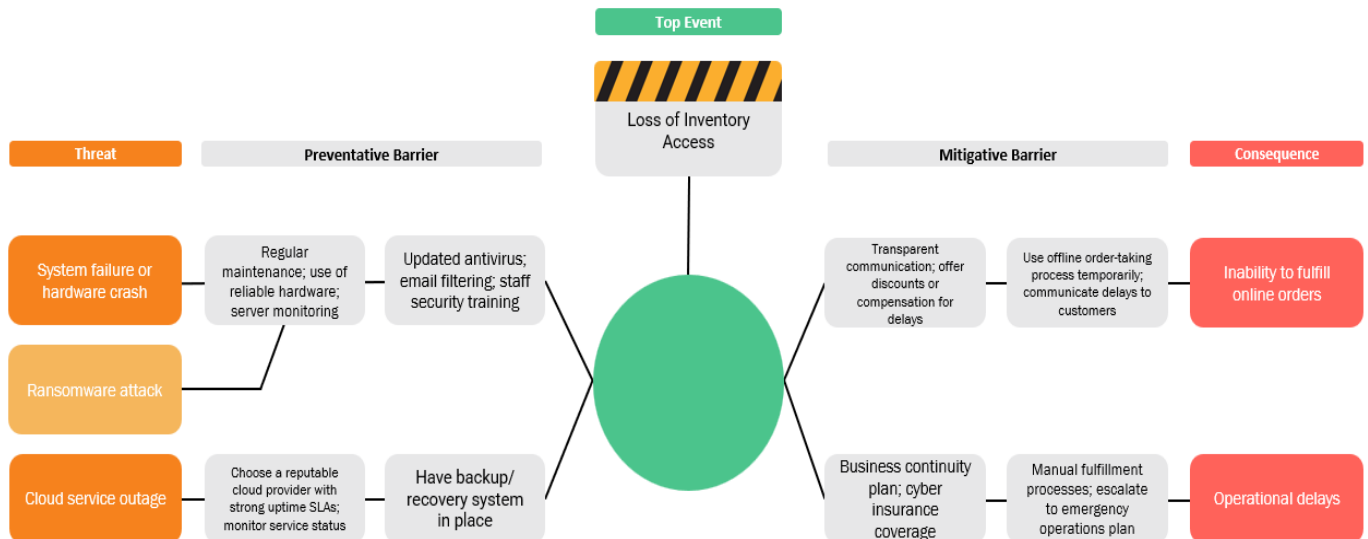
- **E-commerce Website & Backend Platform** – contains front-end for customers to shop items as well as back-end online sales and order processing. If there is an outage this could halt revenue and damage reputation.
- **Point-of-Sale (POS) System** – handles in-store transactions and connects to inventory and customer data. A failure or breach could stop sales and leak sensitive data.
- **Inventory Management System** – Tracks stock levels and integrates with sales channels. Data loss or errors can lead to over/understocking, lost sales, or logistical issues.
- **Employee Records & HR System** – Stores sensitive data such as personal details, contracts, payroll, and performance. Compromise could result in privacy violations and legal consequences.
- **Email & Communication Systems** – Used for internal coordination and external communications with customers and vendors. A breach could lead to phishing, data leaks, or fraud, which could damage the reputation of the company.
- **Financial Systems / Accounting Software** – Contains transaction records, vendor payments, tax documents, and financial reports. Integrity is vital for legal compliance and decision-making.
- **Design Files & Product Blueprints** – For businesses that design their own products, these digital assets represent intellectual property and competitive advantage.
- **Cloud Storage Accounts** – Used for backups and sharing critical files across departments. Misconfiguration or unauthorized access could expose sensitive data.
- **Access Control & User Authentication Systems** – Manages staff logins and permission levels across systems. If unauthorized access is gained, this could lead to malware corrupting the system and data loss.

PHYSICAL ASSETS

- **Company Servers & Networking Equipment** – host internal systems and provide network connectivity. If these are damaged or stolen, it can bring down core operations and prevent sales.
- **Point-of-Sale Terminals & In-store devices** – used for sales and to look up customer details. If stolen or compromised, these can be entry points for attackers.
- **Staff Mobile Devices & Laptops** – often used remotely. If lost, stolen or operating on an unsecured network, these devices are high-risk for data leakage.
- **Security Cameras & Physical Access Control Devices** – help monitor premises and restrict access. If tampered with, they may allow physical access to the store and hinder incident investigations concerning theft and other illegal activity.
- **Paper Records (Invoices, Contracts, Customer Forms)** – loss and theft of these documents can easily result in data breaches and legal issues.

ADVERSE EVENT ANALYSIS

Please refer to the bow tie diagrams below. These detail two key adverse events that could occur and their potential ramifications.



RISK ASSESSMENT AND RATINGS

QUALITATIVE RISK ASSESSMENT MATRIX

Likelihood Scale Table

Likelihood Rating	Description
1 – Rare	May occur only in exceptional circumstances
2 – Unlikely	Could occur at some time, but not expected
3 – Possible	Might occur occasionally
4 – Likely	Will probably occur

5 – Almost Certain	Expected to occur frequently
--------------------	------------------------------

Impact Scale Table

Impact Rating	Description
1 – Insignificant	Negligible effect on business operations
2 – Minor	Small impact, easily recoverable
3 – Moderate	Noticeable disruption
4 - Major	Sever disruption leading to potential legal or financial consequences
5 - Catastrophic	Business – critical impact; significant financial, legal and reputational damage.

Risk Matrix (Likelihood x Impact)

Impact / Likelihood	1 – Insignificant	2 – Minor	3 – Moderate	4 – Major	5 – Catastrophic
5 – Almost Certain	Medium	Medium	High	Extreme	Extreme
4 – Likely	Low	Medium	High	High	Extreme
3 – Possible	Low	Medium	Medium	High	High
2 – Unlikely	Low	Low	Medium	Medium	High
1 – Rare	Low	Low	Low	Medium	Medium

Risk Rating Legend in accordance with Risk Matrix above.

Rating	Meaning
Low	Acceptable, monitor only
Medium	Needs attention and planning
High	Action required, plan to reduce risk
Extreme	Immediate action required

INFORMATION RISK DESCRIPTIONS

Six Information Risks for ABC Retail Store –

1. **Unauthorised Access to Customer Data**

ABC Retail Store stores sensitive information regarding customers, including first and last names, emails, postal addresses and payment details in its database. If a breach occurs and data is leaked, it could lead to identity theft, heavy fines for non-compliance and severe damage to the company's reputation.

Actor	External Cybercriminal.
Asset	Customer Information Database – customer names, email addresses, postal addresses, phone numbers, payment details etc.
Threat	Data breach and identity theft.
Vulnerability	Lack of encryption and weak access controls.
Impact	Legal fines, reputational damage, customer loss and revenue loss.

2. **Ransomware Attack**

Outdated or unpatched software could lead to a ransomware attack on ABC Retail Store's systems. An attacker could infect the system via a phishing email or malicious file, which would mean a demand for ransom. This could cause widespread disruption to operations, data breaches and financial losses.

Actor	External attacker (via phishing).
Asset	Point-of-sale and inventory management system or otherwise operational systems.
Threat	Systems become locked and inaccessible causing operational disruption.
Vulnerability	Unpatched software and lack of staff training.
Impact	Inability to process sales, operational downtime, financial losses.

3. Loss of Unsecured Mobile Device

Due to remote working arrangements, many employees use personal mobile devices which lack the proper security measures such as encryption, screen locks, or remote wipe capabilities. This means if a device is lost or stolen, sensitive company data could be exposed leading to a data breach.

Actor	Employee.
Asset	Company data on employee mobile phone.
Threat	Data leak due to theft or loss of device.
Vulnerability	No encryption or remote wipe enabled.
Impact	Exposure of internal communications or sensitive business info.

4. Insider Misuse of Admin Credentials

Employees with administrative access to key systems present an insider threat if access is not properly monitored and managed. A disgruntled or careless employee could misuse their credentials to alter data, sabotage systems, or steal information. It is important to audit access controls regularly and ensure that privileges are retracted once an employee leaves the company.

Actor	Disgruntled employee.
Asset	Admin-level access to store systems.
Threat	Unauthorised system changes or data theft.
Vulnerability	Poor monitoring and no role-based access.

Impact	System disruption, data corruption, and internal investigation.
--------	---

5. Website Downtime from Poor Security Configurations

Poor security configurations such as an outdated CMS, insecure plugins, and an improperly configured firewall increase the risk of cyberattacks. A hacker could deface the website, perform a denial-of-service (DoS) attack, or exploit vulnerabilities to take it offline.

Actor	External attacker or automated bot.
Asset	E-commerce website.
Threat	Denial-of-service or defacement attack.
Vulnerability	Misconfigured firewall, unpatched plugins.
Impact	Lost sales, loss of customer trust, search engine penalties.

6. Data Loss Due to Inadequate Backups

ABC Retail Store lacks a reliable backup plan for critical digital assets, such as customer records and transaction data. If data is lost due to hardware failure, ransomware, or accidental deletion, recovery may not be possible.

Actor	Internal failure or ransomware attack.
Asset	Sales records and customer data.
Threat	Permanent data loss.
Vulnerability	Lack of reliable or recent backups.

Impact	Operational disruption, legal consequences.
--------	---

RISK RATING ASSIGNMENT

Risk	Likelihood	Impact	Risk Rating	Justification
1. Unauthorised Access to Customer Data	4 – Likely	5 – Catastrophic	Extreme	The lack of encryption and weak access controls make a data breach highly likely. Impact is catastrophic due to legal, financial, and reputational damage.
2. Ransomware Attack	3 – Possible	4 – Major	High	Ransomware is a common threat and systems are outdated. Impact would be significant due to downtime and sales loss.
3. Loss of Unsecured Mobile Device	4 – Likely	3 – Moderate	High	Devices are used often but poorly secured, making loss likely. Impact is moderate unless sensitive data is involved.
4. Insider Misuse of Admin Credentials	2 – Unlikely	5 – Catastrophic	High	While less likely, if it does occur the damage could be critical, especially with admin access.
5. Website Downtime from Poor Security Configurations	3 – Possible	4 – Major	High	Website attacks are common. Poor configurations raise the risk, and downtime directly affects income.
6. Data Loss Due to Inadequate Backups	2 – Unlikely	5 – Catastrophic	High	Rare but devastating if it happens, especially with no working backups in place.